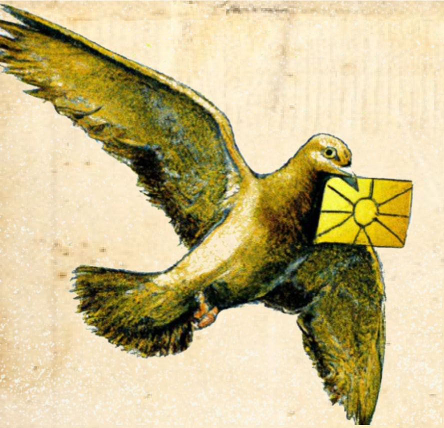


DEFCON

August 2023

Cellular Carriers Hate This Trick

Using SIM Tunneling to Travel at Light Speed

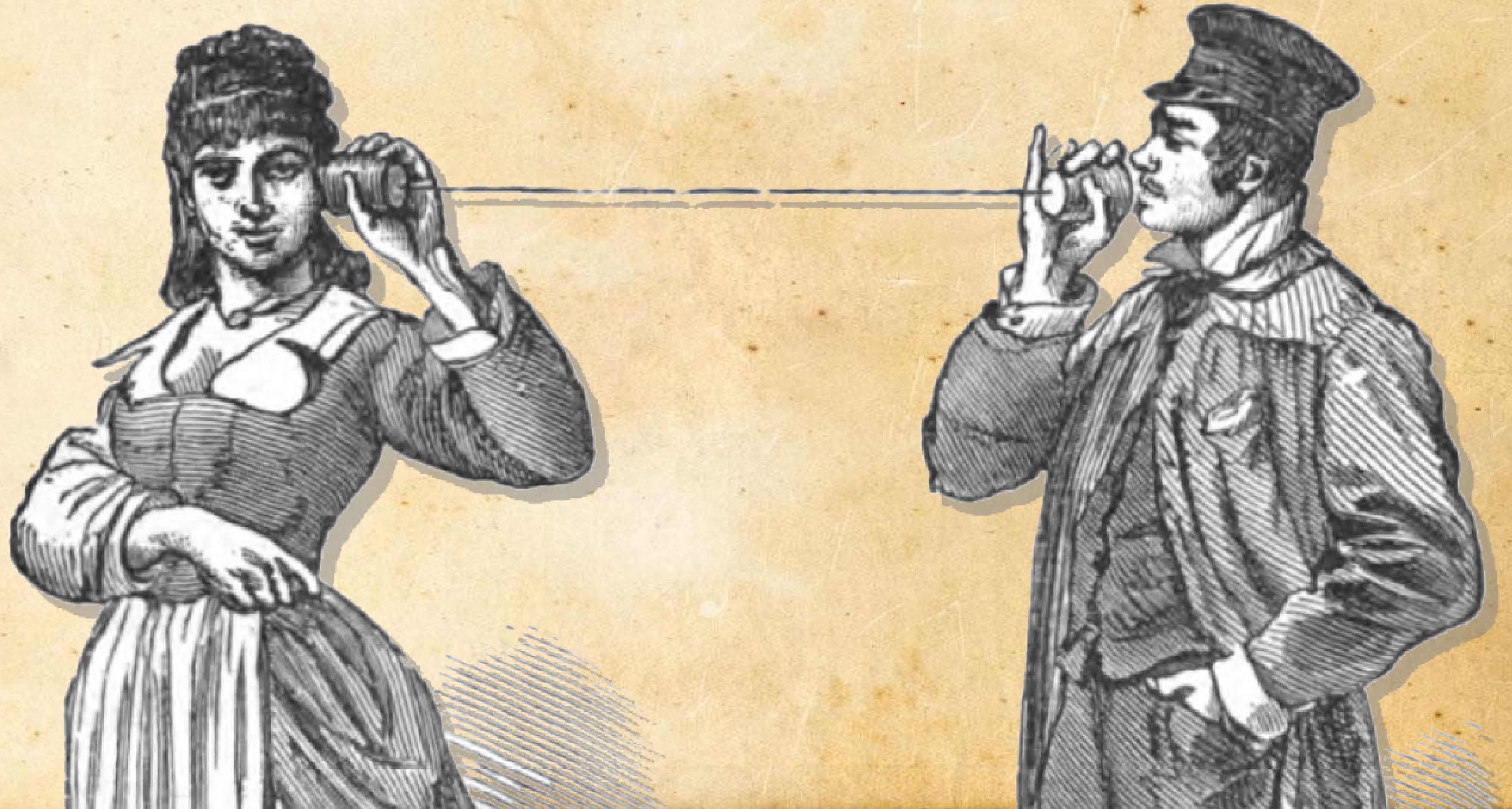
Speaker: Gabriel Gegenhuber, Adrian Dabrowski

Co-Authors: Wilfried Mayer, Edgar Weippl

v1.0

Three City States

From Landline ...



... to Wireless!

Three Major MNOs

KnighT Mobile

Three Major MNOs

Three Major MNOs

Three Major MNOs + more

Red-Yellow
Air

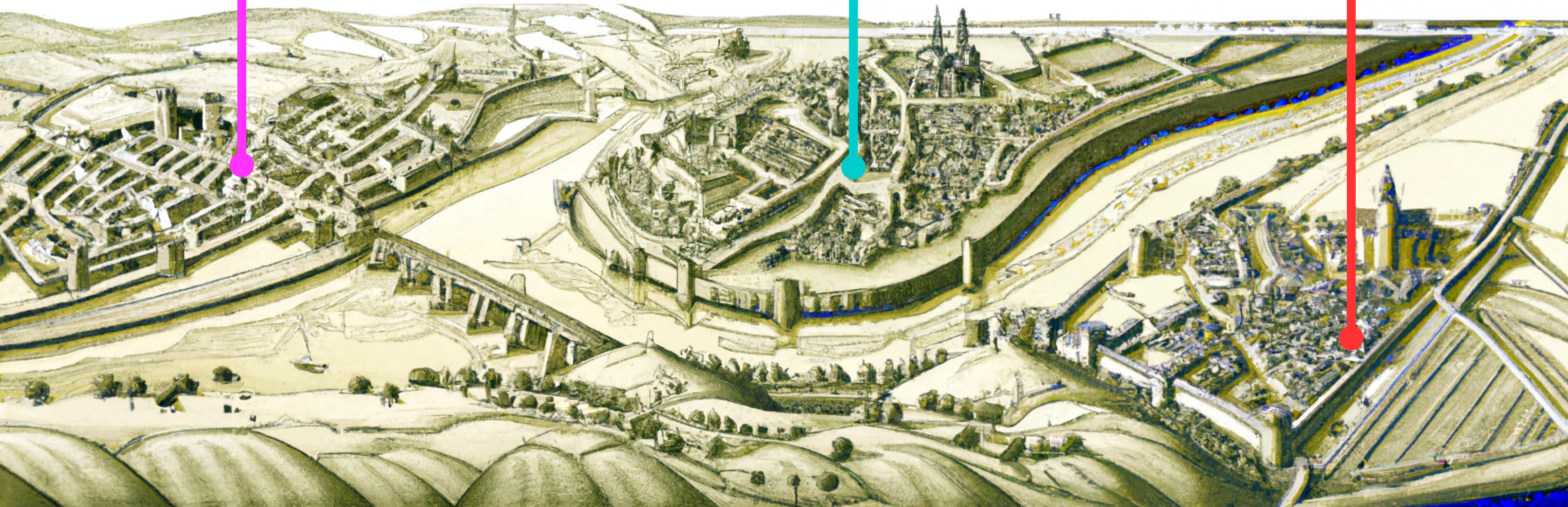
KnighT Mobile

Marathon
HelvetiaCom

AT&X

Trinity
Gentlebank

dragonfone



Social Network Explosion

RoyalTweet

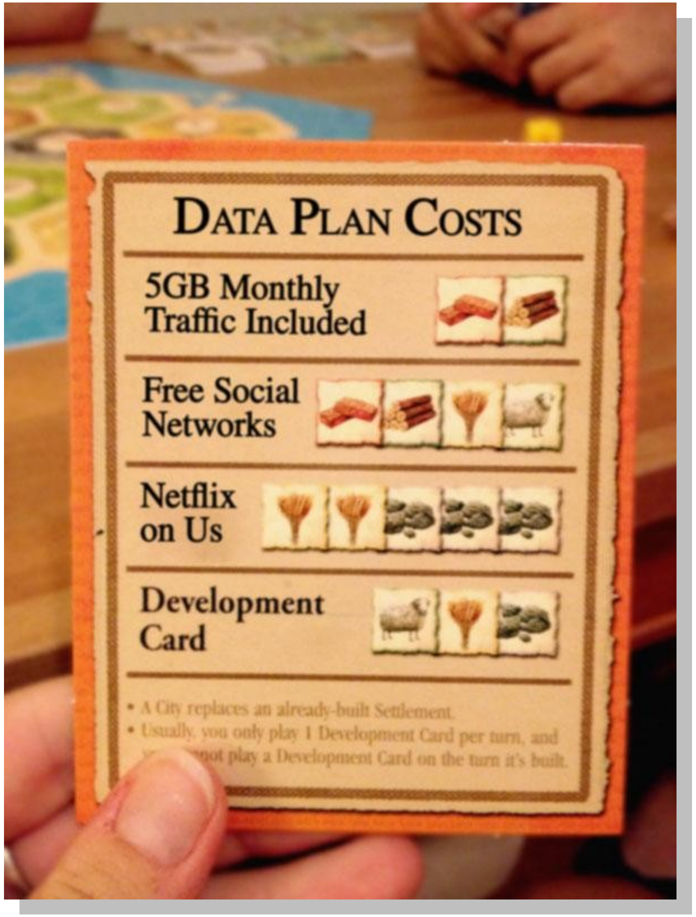
Pidgingram

JesterGram

BardBoard

PesantPost

Combos with “Free” Traffic



- Popular with certain demographics
- Monthly data allowance
  - PLUS FREE:
    - Video Streaming
    - Audio Streaming
    - Social Networks
    - ...

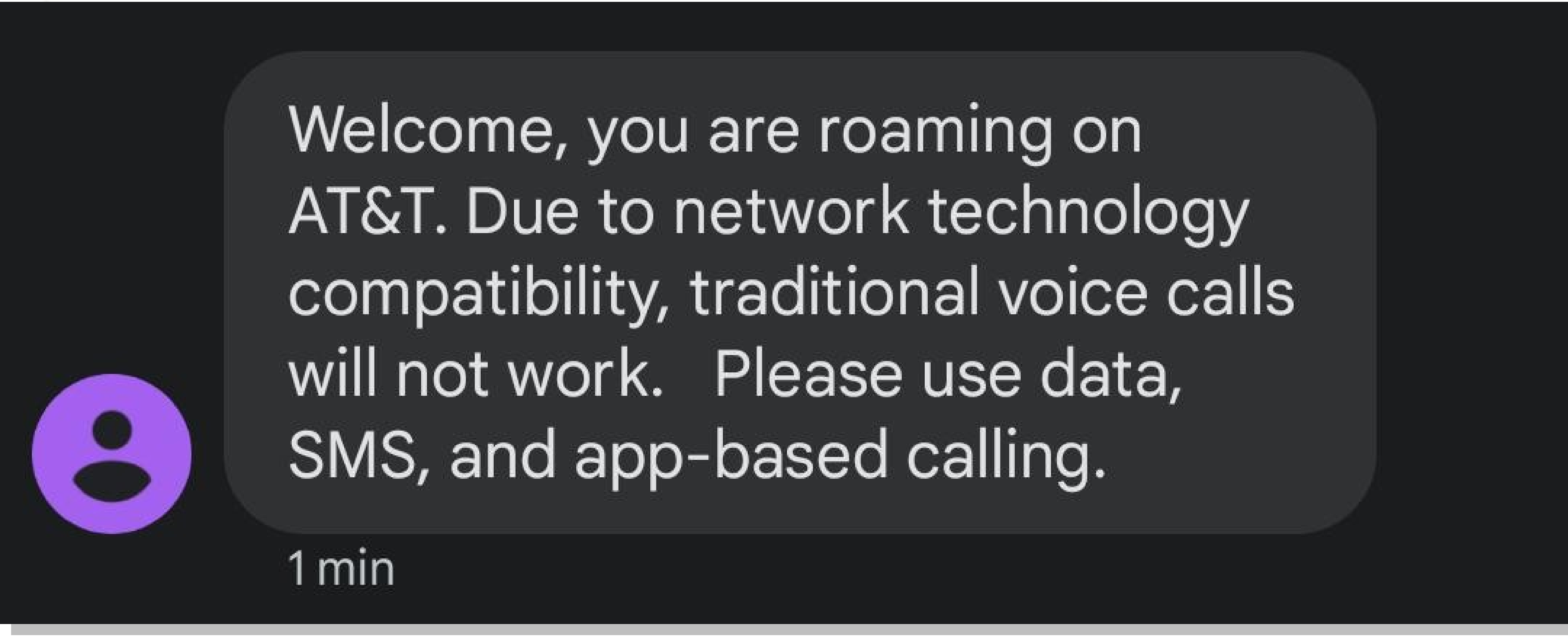
Real (Addictive) Transformation

This is Archibald

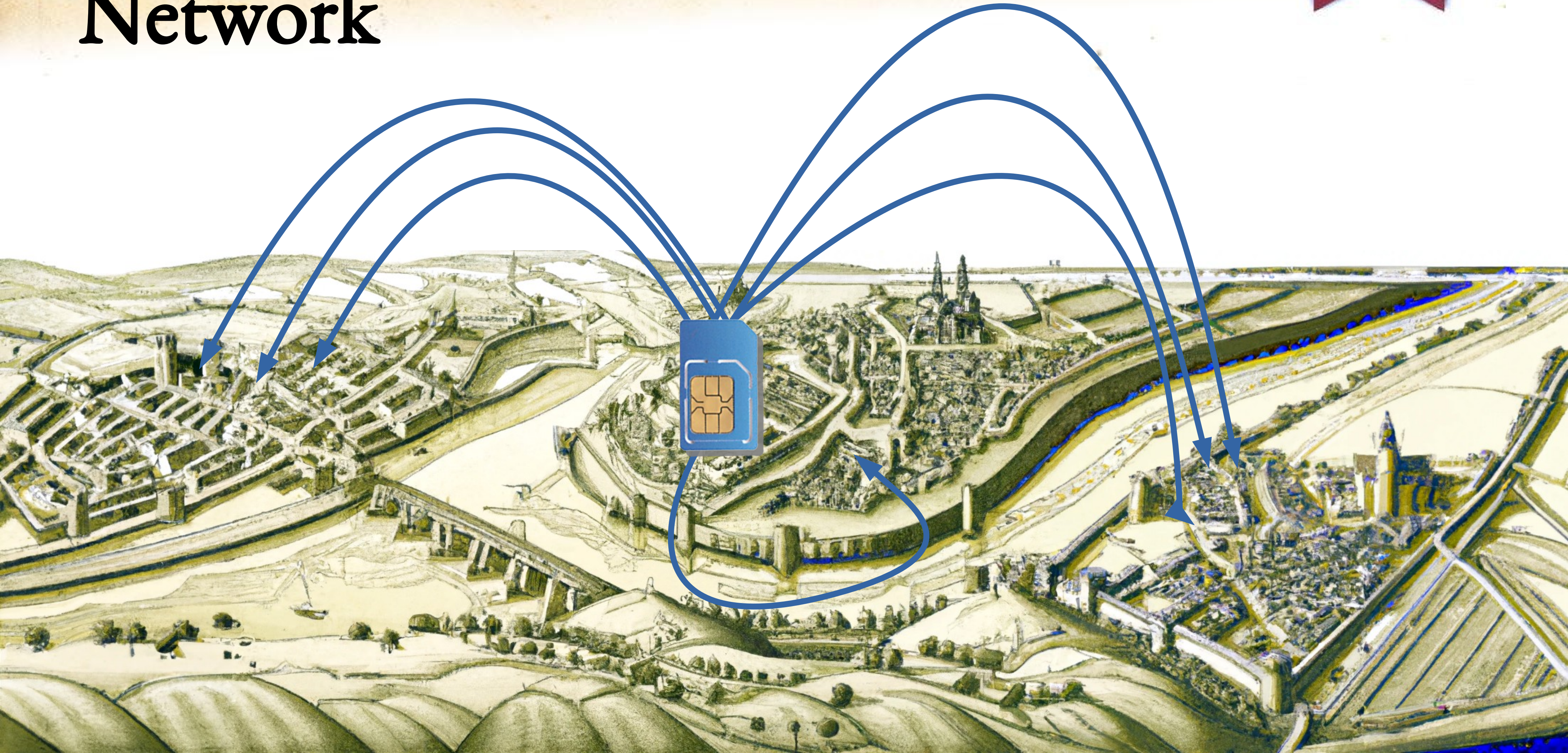
- Has a data plan with free social networks (“zero-rated”)
- Likes to visit his friends “abroad”
- Has found a traffic accounting vuln.
- Repeatedly experiences roaming oddities



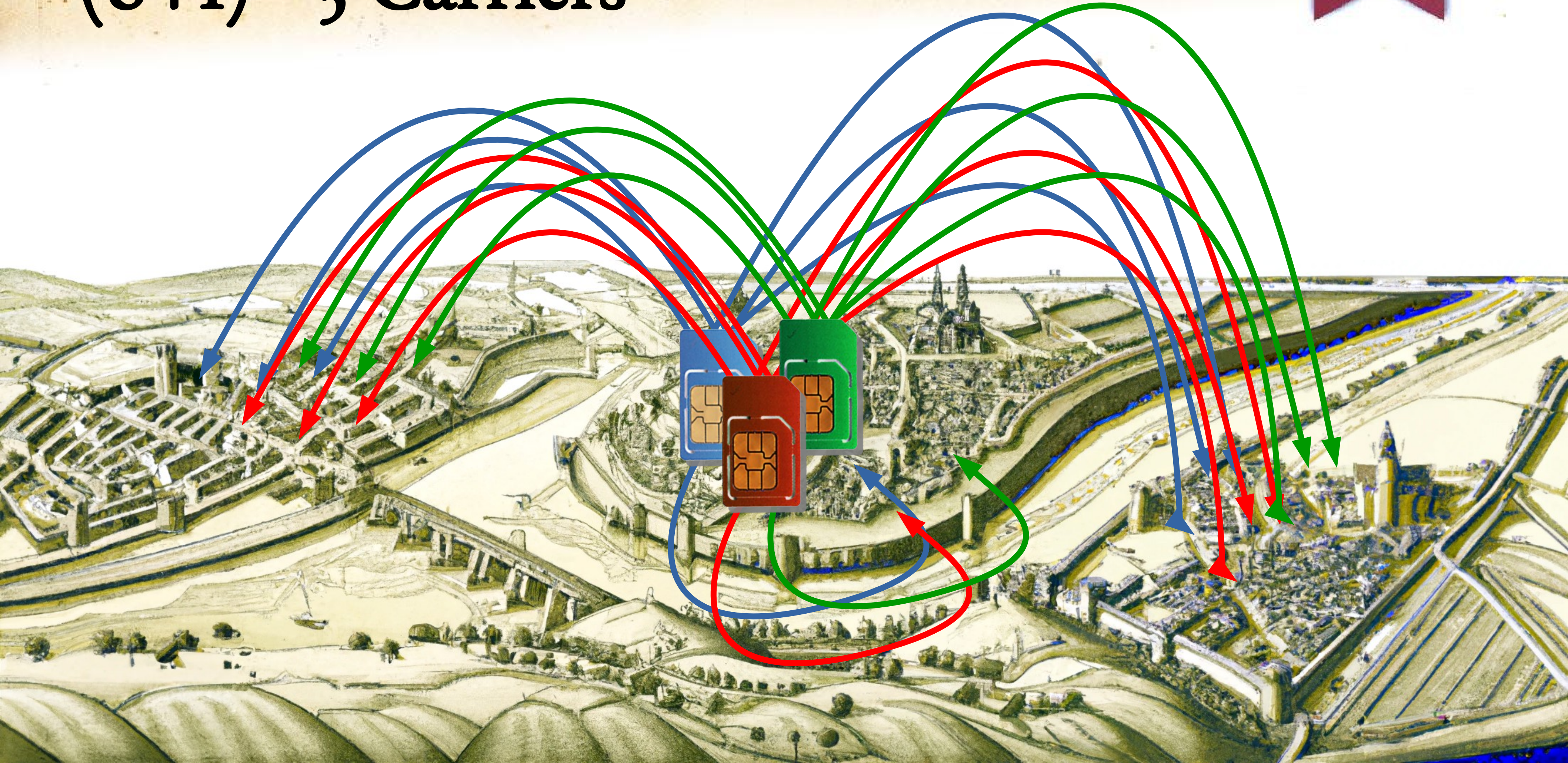
And Then, There is VoLTE Roaming…



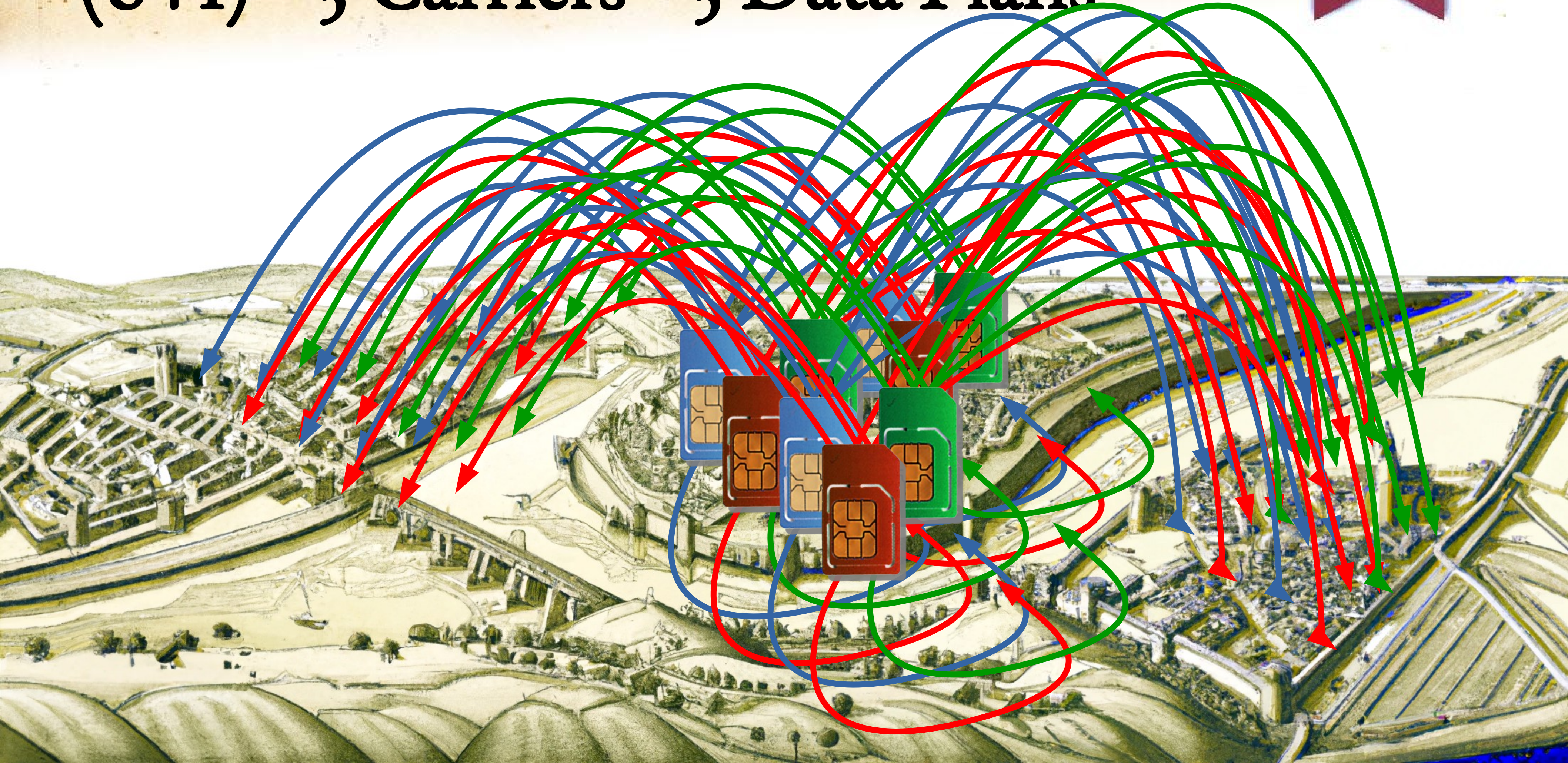
One SIM has 6 Roaming + 1 Home Network



(6+1) * 3 Carriers



(6+1) * 3 Carriers * 3 Data Plans

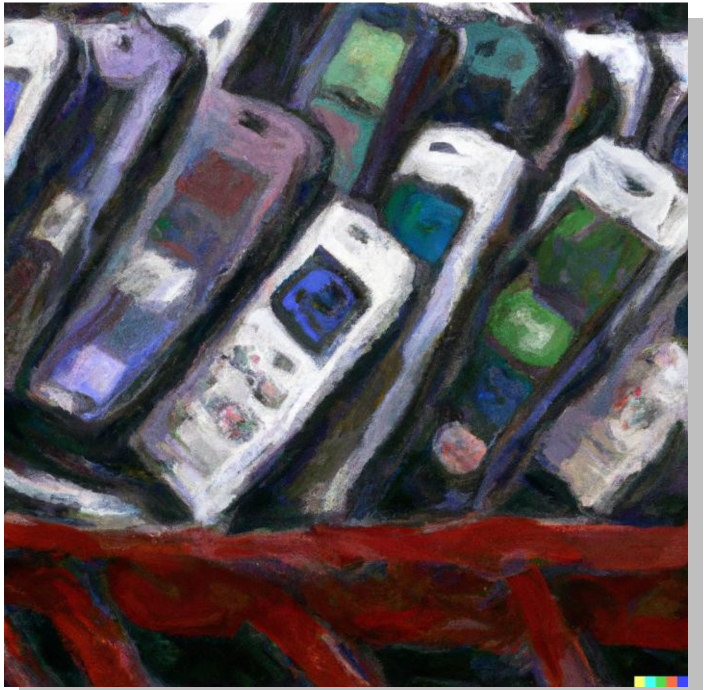


(6+1) * 3 Carriers * 3 Plans * 3 Territories

(6+1) * 3 Carriers * 3 Plans * 3 Territories = 189

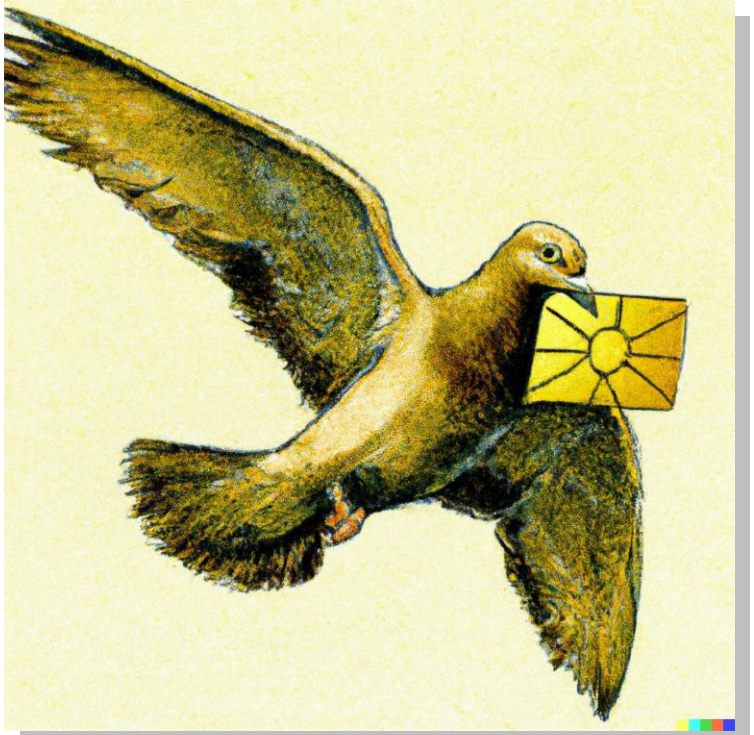
How to Automate?

- Buy a lot of SIMs and a lot of modems
  - Hardware costs
  - Monthly costs



How to Automate?

- One modem at each territory, and ship SIMs around
  - Low hardware overhead
  - Long shipping times
  - Manual labor



Decouple SIM and Phone/Modem

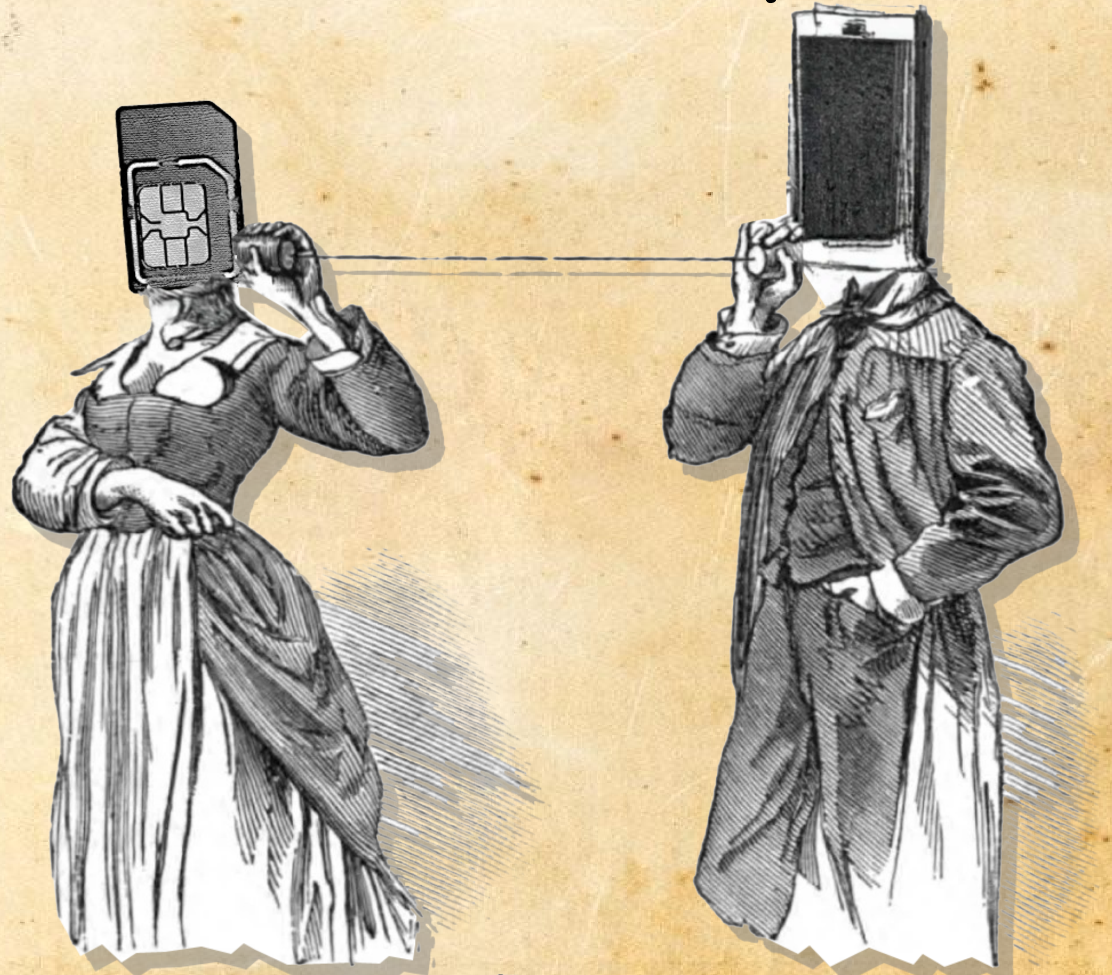


Fig. 6.

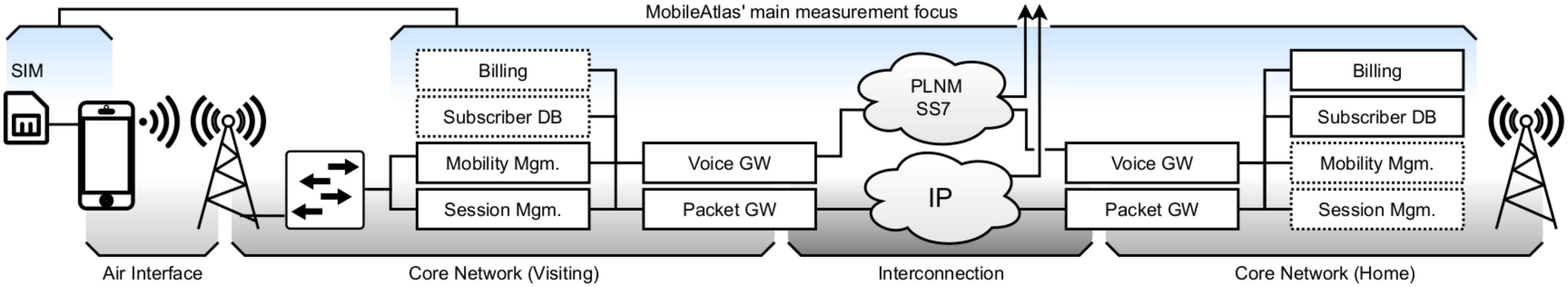
A New Witchcraft to Travel at Light Speed

MobileAtlas

Geographically Decoupled Cellular Measurements & Exploitation

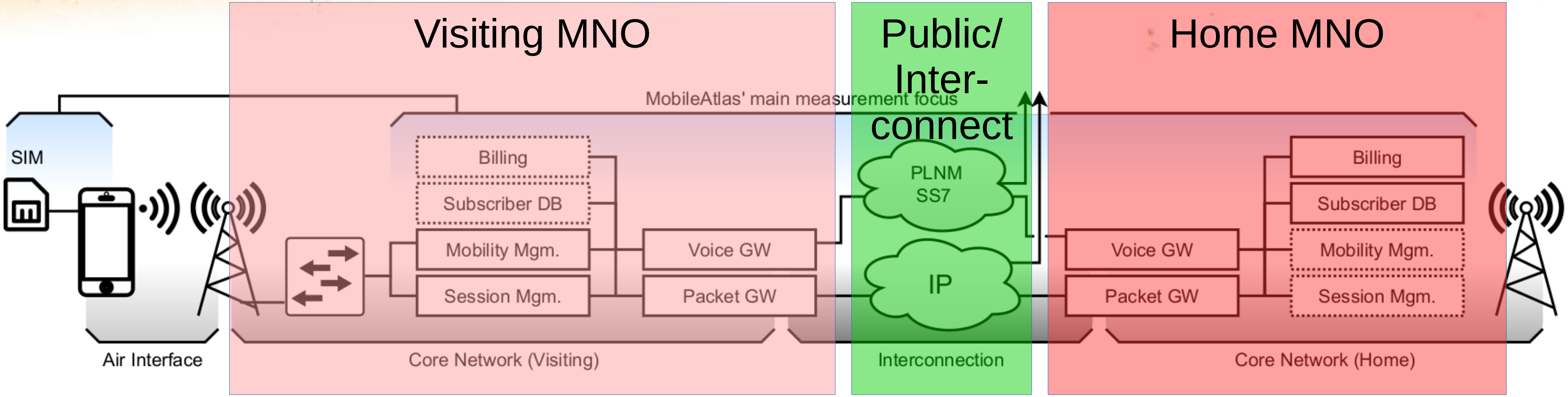
mobile atlas

Why Roaming is Interesting?



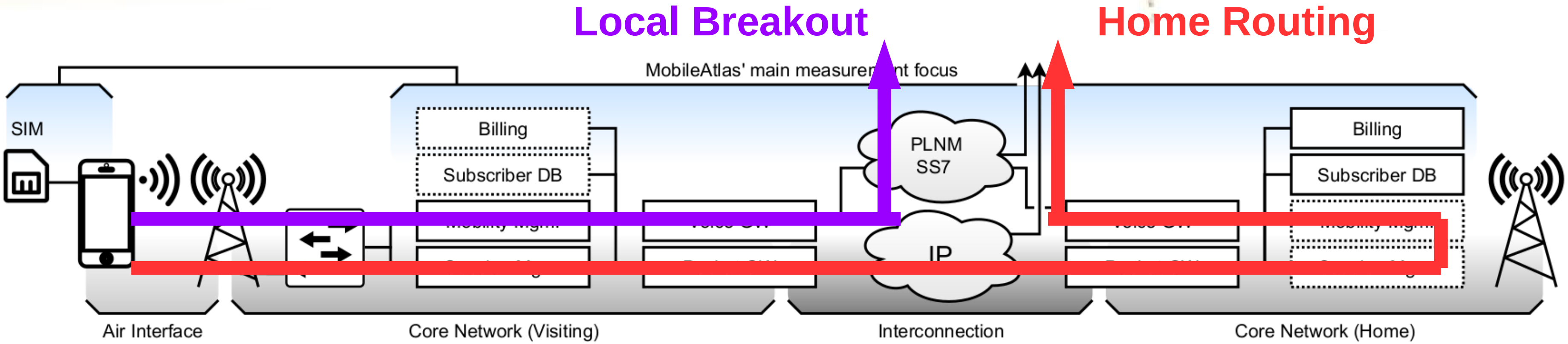
- Visiting and Home network need to work together
- Some traffic passes both, other just the visiting MNO
  - Data typically uses home routing (except Travel SIMs and Google Fi)
  - Voice typically uses local breakout for latency, but with a custom CallerID

Why Roaming is Interesting?



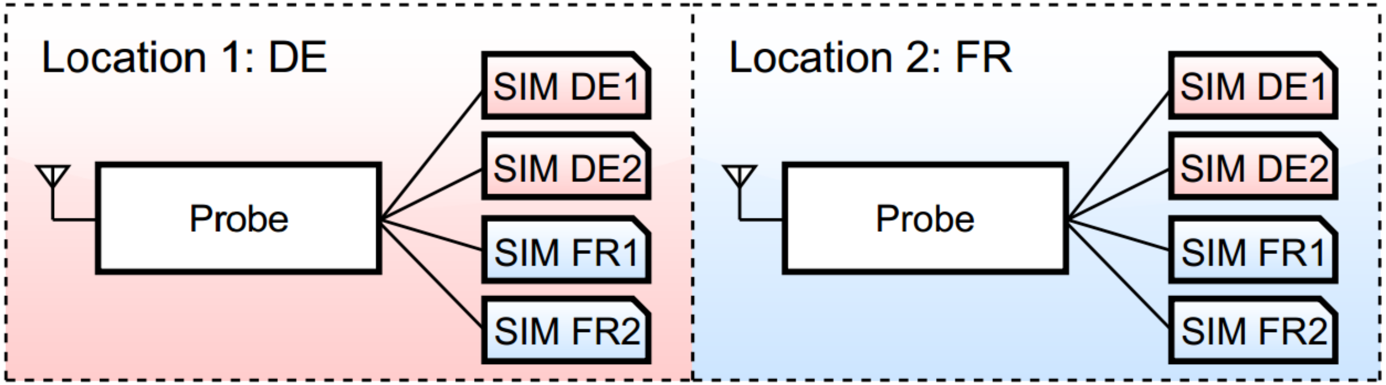
- Visiting and Home network need to work together
- Some traffic passes both, other just the visiting MNO
  - Data typically uses home routing (except Travel SIMs and Google Fi)
  - Voice typically uses local breakout for latency, but with a custom CallerID

Why Roaming is Interesting?

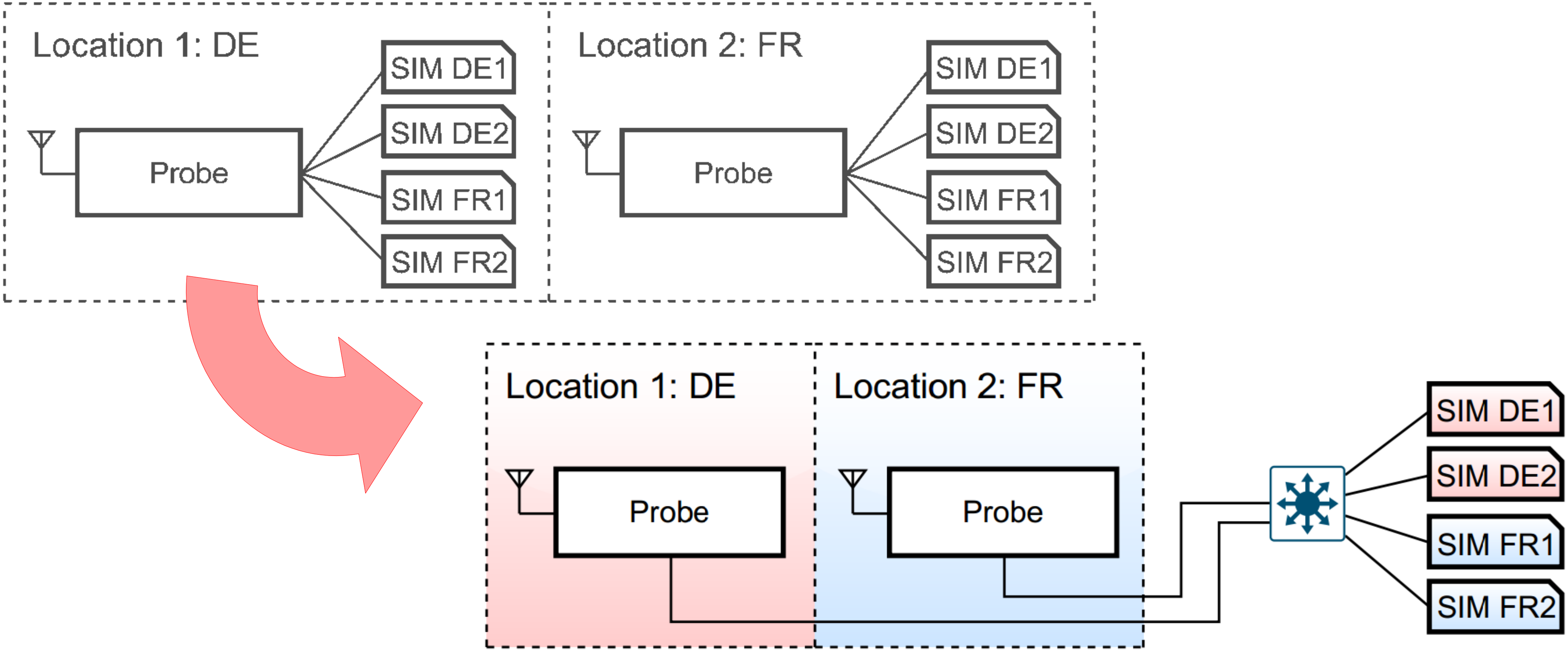


- Visiting and Home network need to work together
- Some traffic passes both, other just the visiting MNO
  - Data typically uses home routing (except Travel SIMs and Google Fi)
  - Voice typically uses local breakout for latency, but with a custom CallerID

Combating the Combinatorial Explosion



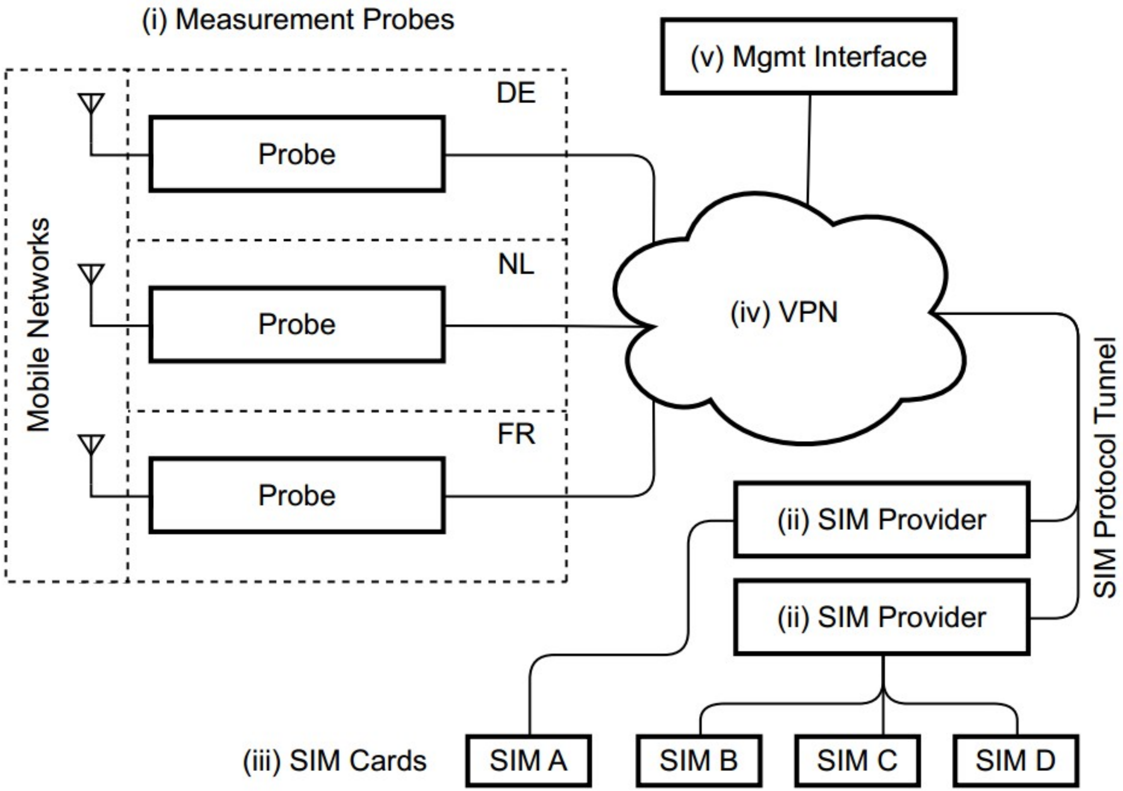
Combating the Combinatorial Explosion



Other Goals

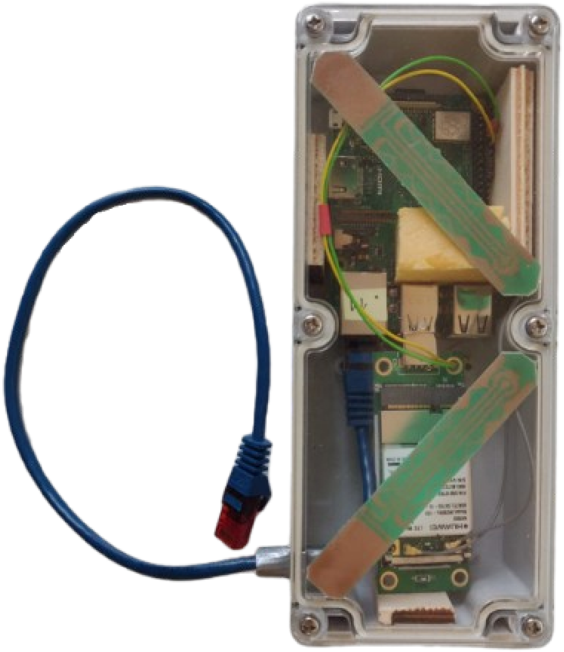
- Scalability
- Automatability
- Control background noise
- Low-cost, open design
- SIM communication
- Full feature spectrum

MobileAtlas Platform Architecture



Hardware: Probes

Version 1 (2019)



Version 2 (2022)

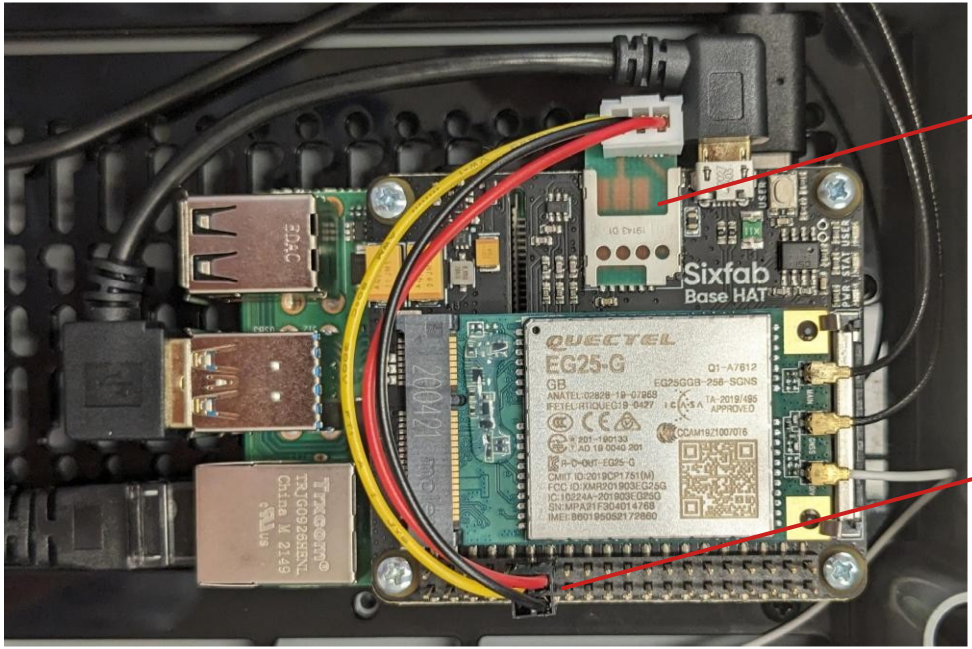
Hardware: SIM Provider

- SIM Provider software executed on system (e.g., laptop)
- SIM card attached to system
  - PC/SC Reader
  - “Cheap” SIM Reader
  - Modem (AT+CSIM)
  - Android Phone (via Bluetooth rSAP)

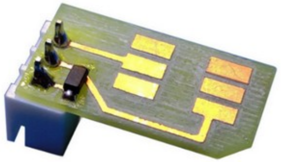
Challenges (Selection)

- SIM protocol
  - In-device, low latency
    - But network has latency
  - Synchronous I/O
  - 1-5 Mhz clock speed
  - Multiple volages
- Traffic metering
  - Control our background traffic
  - CDR often not realtime
    - ~ Hours, domestic
    - ~ Days, roaming
  - No Standard
    - Web, SMS, App, USSD

SIM Interface



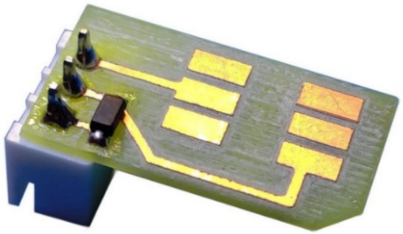
SIM Adapter

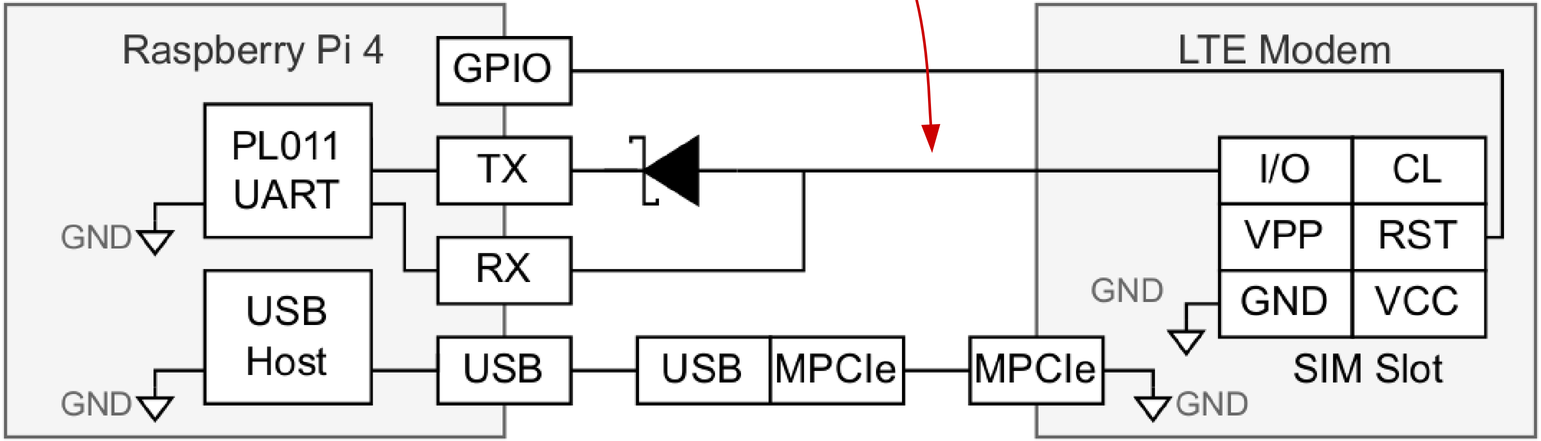


GPIO Ports (UART)

SIM Interface

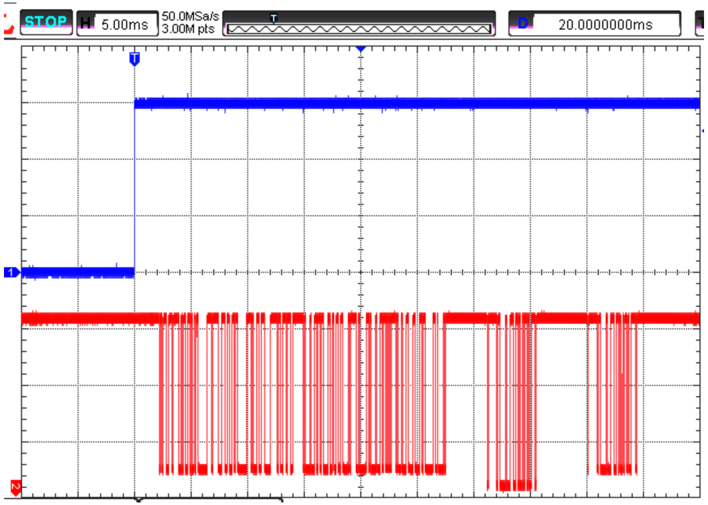
“Open Collector Bus”
modem provides pull-up





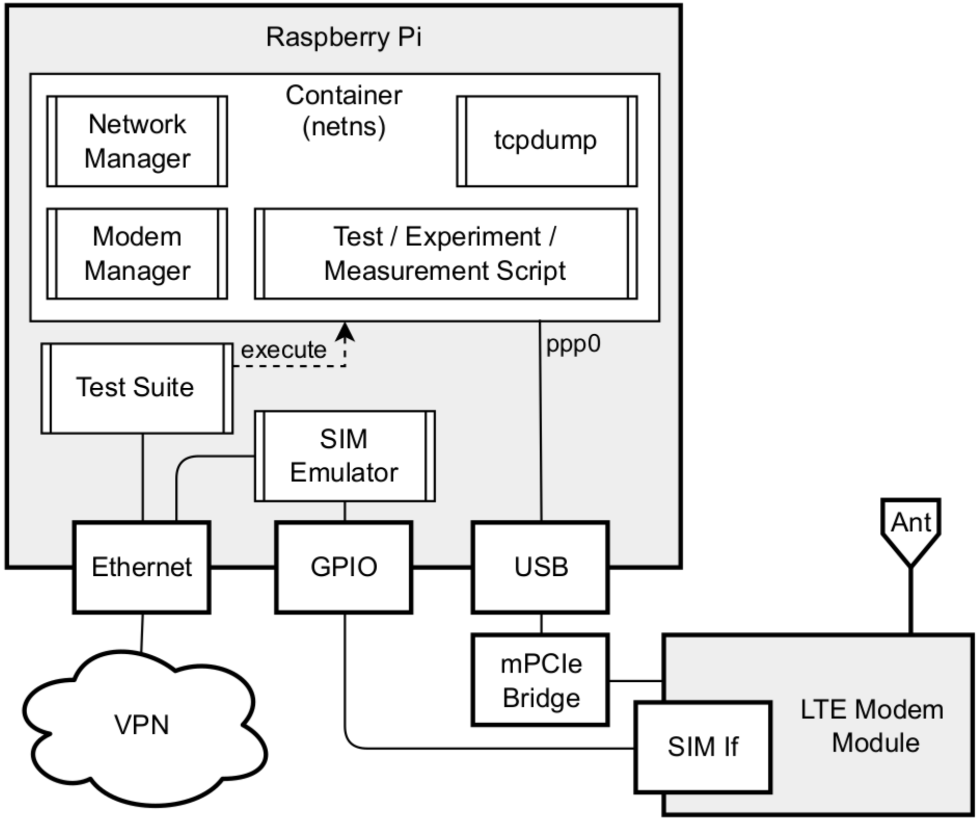
SIM Interface

- We can negotiate speed & electric parameters independently (SIM Provider, Modem)
  - 1.8V, 3V, 5V
  - ATR and PPS
- Waiting Time eXtensions (WTX)
  - We tested 1000 ms latency
- Future work: cache/emulate some files locally.



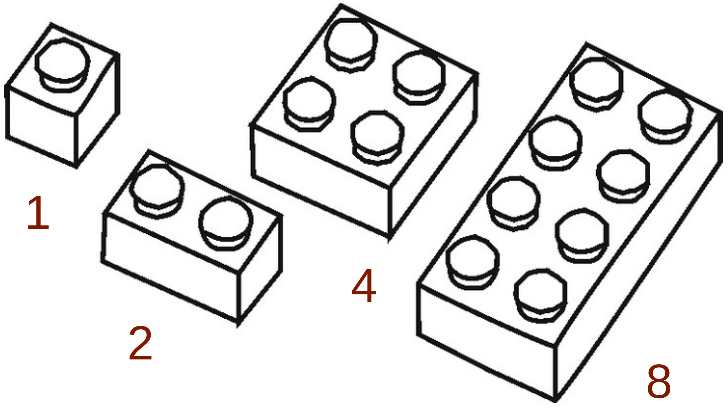
Eliminate Background Traffic

- Only one container is connected to the modem’s data connection
- Linux network namesapce



Delayed Traffic Accounting

- Charge Data Records (CDR) are often delayed by hours
- Use **binary encoding** for size of testing data: size $= 2^{testnr}$ MB
- Hours later, we can unambiguously distinguish which traffic was accounted and which was free.

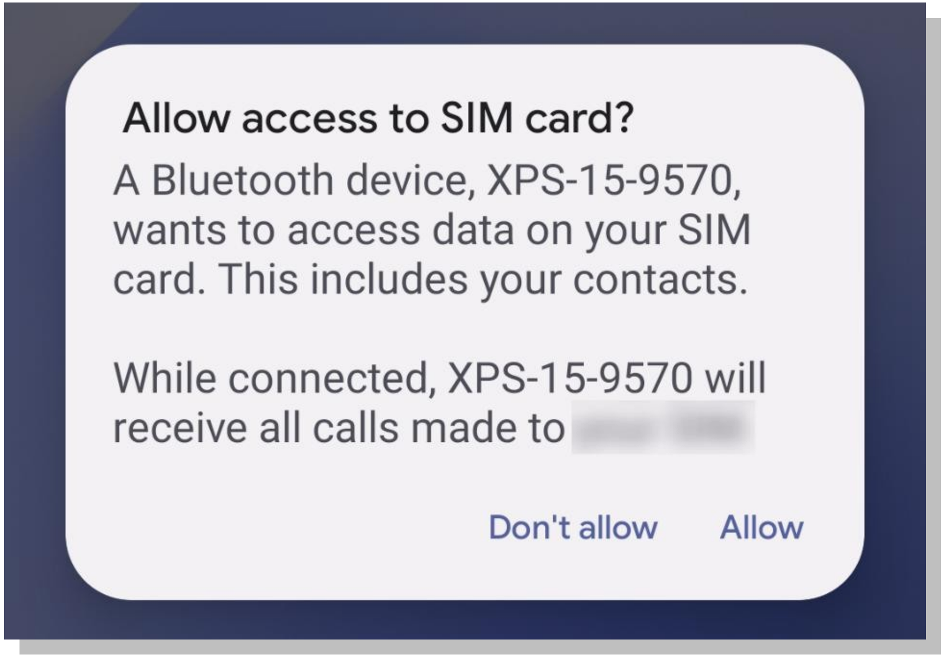


eSIMs ?

- Not universally available
- Not universally transferable
- We include them in MobileAtlas via BT rSAP Prototcol
  - Android Phone connects to SIM Provider system (e.g., Laptop) and shares its SIM card

SIM Access Profile on Android

- Broad support on Pixel devices
  - No root required
- Always serves primary SIM
  - Possible to relay eSIMs :-)



Why the “carriers hate this trick”?

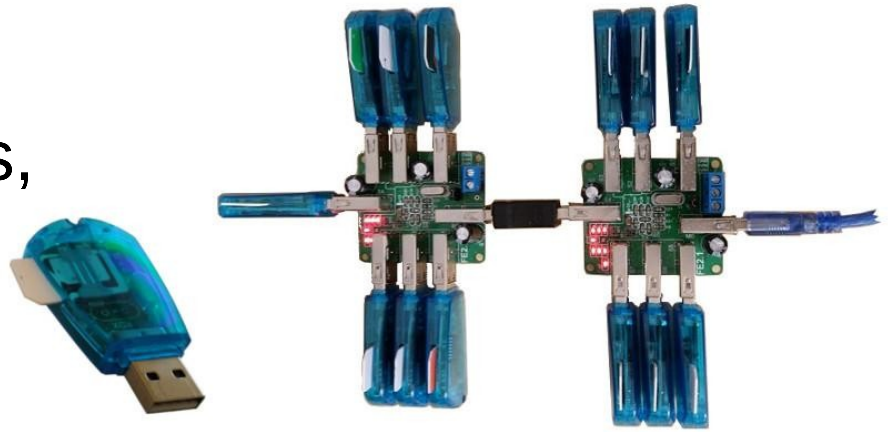
- SIM tunneling used before for “over-the-top bypass fraud”
  - “grey” international carriers will use local SIM cards to terminate calls in a given country
    - This sometimes also use SIM tunneling aka “SIM boxing”
  - Local call rates are often cheaper than official termination fees
    - Lost fees
    - More over-the-air congestion in that cell

Why the "carriers ~~hate~~ love this trick"?

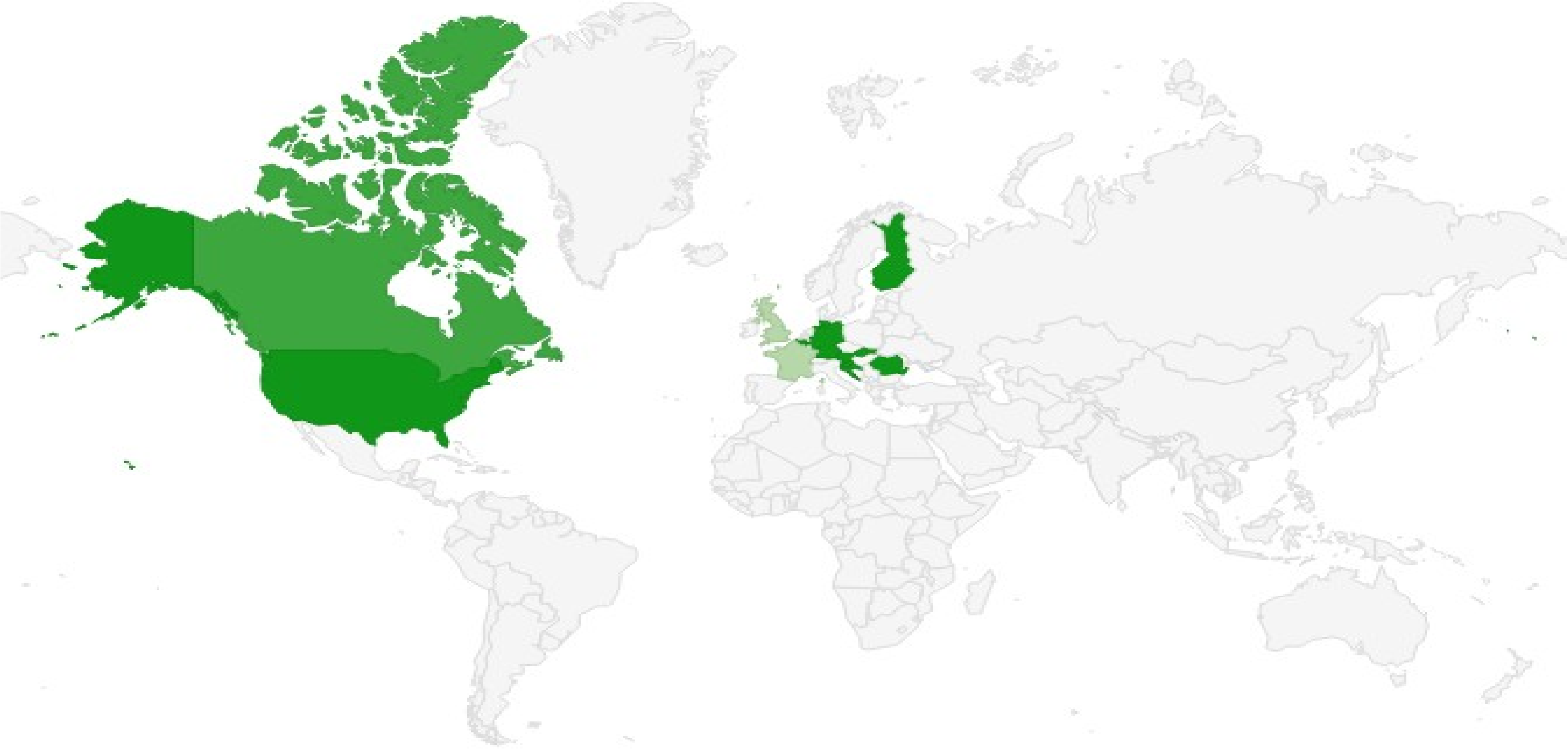
- However:
  - MobileAtlas can also be helpful for carriers
    - Make tests from outside their physical presence
    - Verify their roaming configurations
      - e.g., VoLTE Roaming, traffic accounting
    - Test corner cases

Things We Have Learned...

- IMSI is not a good primary key for a SIM card
  - SIMs change IMSI to select roaming partner network
  - Travel SIMs (also Google FI) are cloud-controlled SIMs
- Hard to reach USB’s 127 device limit
  - Lousy hardware, weak drivers, power consumption



Where Do We Stand Today?



Ethical Considerations

- Radio regulation
  - Modems unaltered
  - No SDR
- No enrichment
  - We let expire same or bigger amount of unaccounted traffic from our data allowance.
- Network influence
  - No DoS, no abnormal traffic amounts
- Local LAN
  - All traffic via VPN
- SIM registration
- Guest LAN access

Measurement & Exploits (Selection)

Exhibit A: Zero Rating and Free Riding

Free Riding, Zero Rating

- Internal Services
  - DNS, Service Center, Balance top up
- External Services

Zero-Rating: Carrier Perspective

- Data traffic needs to be separated
  - Billed traffic
  - Zero-rated traffic
- Classification of traffic that belongs to zero-rated applications
  - Based on various metrics

Traffic Classification: Popular Metrics

- TCP/UDP port
  - Vague
- IP address
  - Accurate
    - CDNs?
  - Dynamic cloud hosting can change Ips frequently
- TTL
  - Used to detect tethering
- DPI
  - Protocol
  - Hostname
- Machine Learning
  - Detect various patterns/metrics within packet flow

Zero-Rating Study

- Measured 7 operators (of 3 European countries)
- WhatsApp, Snapchat, Facebook/Messenger
  - Communication via WebAPI
    - HTTP, HTTPS, HTTP3
    - IPv4, IPv6
- Measured all operators and applications in 8 countries

Hostname-based Classification

HTTP (plaintext)

- Classified via Host Field

```
GET / HTTP/1.1
Host: mobileatlas.eu
User-Agent: Mozilla/5.0
Accept-Language: en-US
Accept-Encoding: gzip, deflate
Connection: keep-alive
```

HTTPS, HTTP3 (TLS)

- Classified via SNI Field

Zero-Rating Study: Results

USED CLASSIFICATION METRICS AT THE TESTED OPERATORS AND APPLICATIONS

Operator	Roaming	WhatsApp	Snapchat	Messenger/Facebook
AT-1	Yes	IP	IP, Host	$
AT-2	Yes	IP	IP[a]	IP
AT-3	Yes	IP	×	$
HR-1	No	IP	Host	IP
HR-2	Yes	IP	IP, Host[b]	IP
RO-1	No	IP, Host[b]	×	IP, Host[b]
RO-2	×	IP[c]	×	×

$ traffic fully billed. × not part of zero-rating tariff.
[a] IPv4 only. [b] HTTPS only. [c] TCP only.

Phreaking Revised: Spoof Hostname

- Hostname-based classification
  - HTTP
    - Write custom relaying script
    - Sometimes only simple regex within first bytes of packet
  - HTTPS/HTTP3
    - Use TLS-based VPN (e.g., OpenVPN) and spoof SNI Header

Phreaking Revised: Spoof IP

- IP-based
  - Send packets with spoofed IP address to client
    - Works for dowlink only
    - Relatively easy for UDP
    - QUIC🤝WireGuard

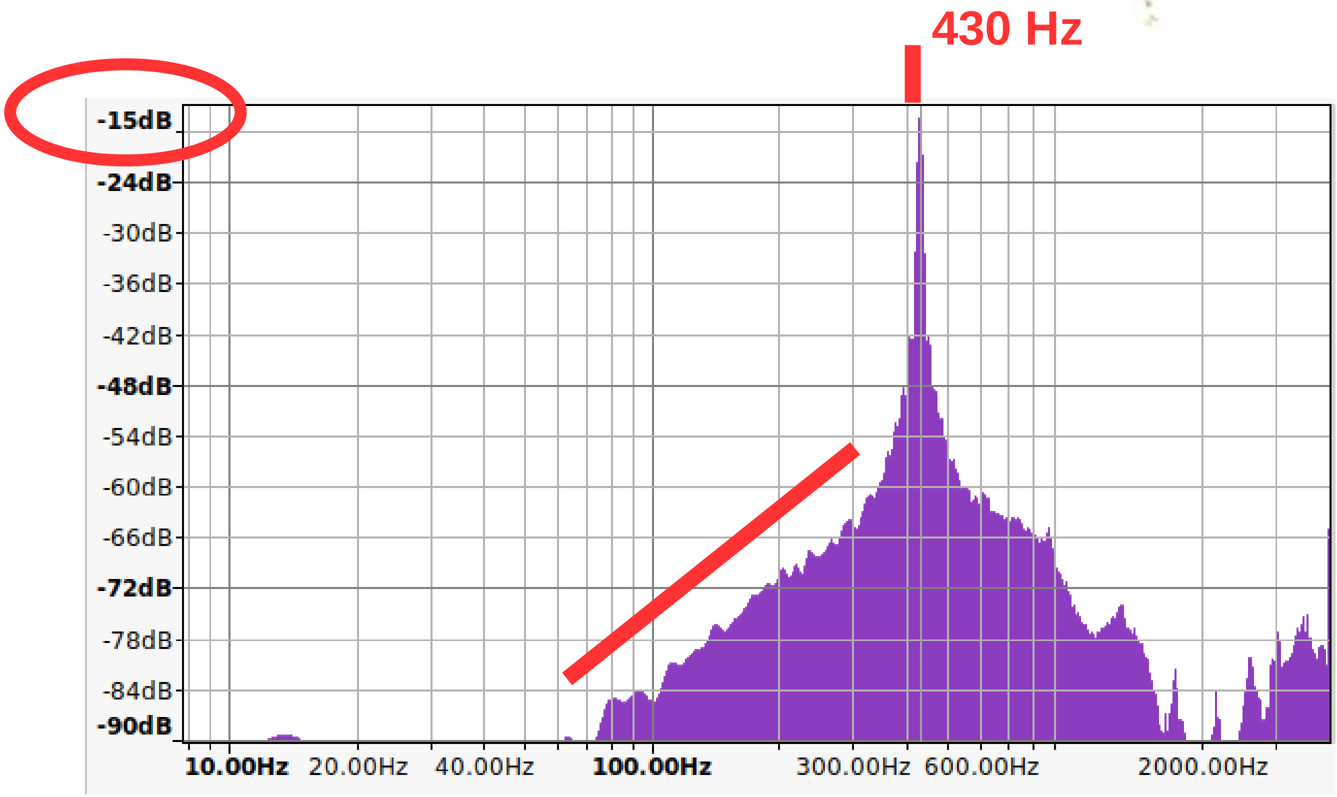
Measurement & Exploits (Selection)

Exhibit B: User Tracking with Call Progress Tones

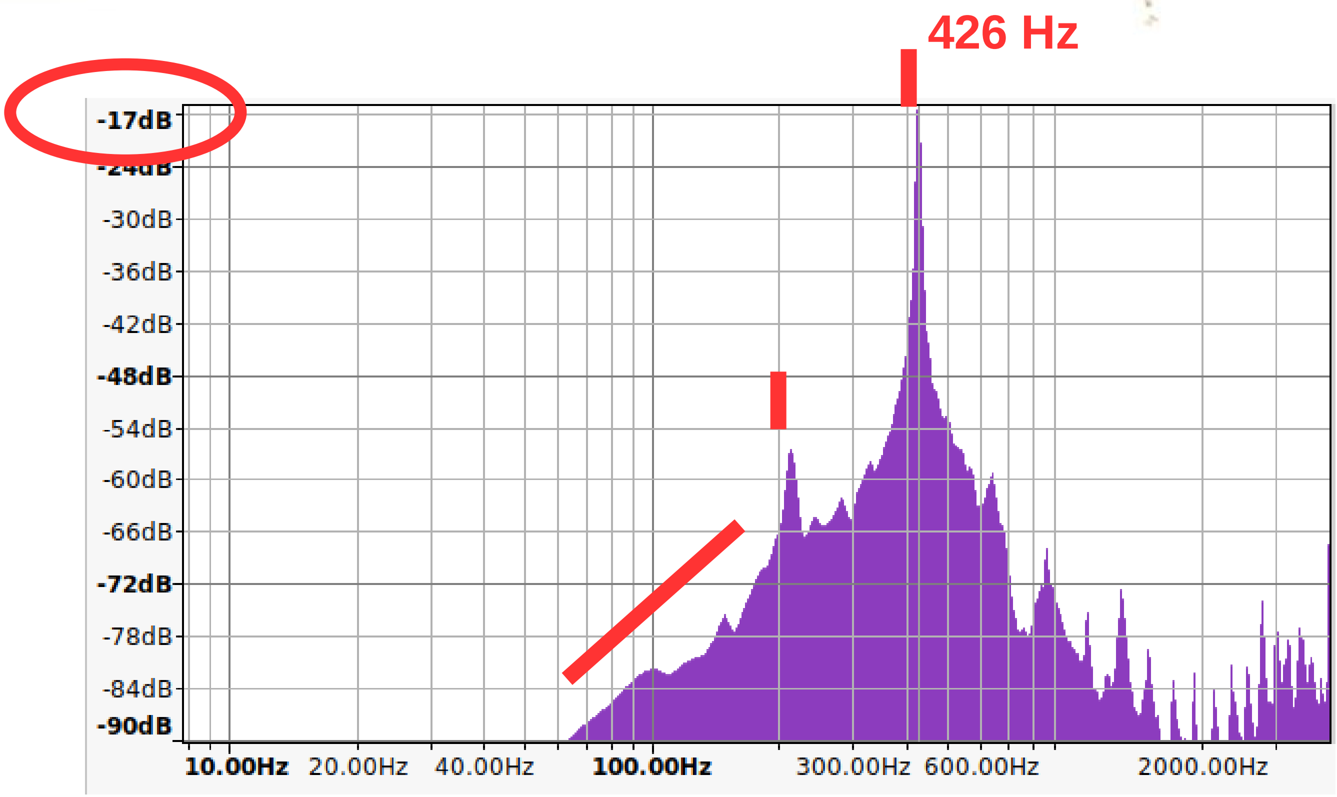
Call Progress Tones

- Can be generated out-of-band
  - Usually by the originating network or the phone itself
- More often “early media” is used
  - The target network generates ring back and busy tones
  - Allows for additional services (wait-tone music)

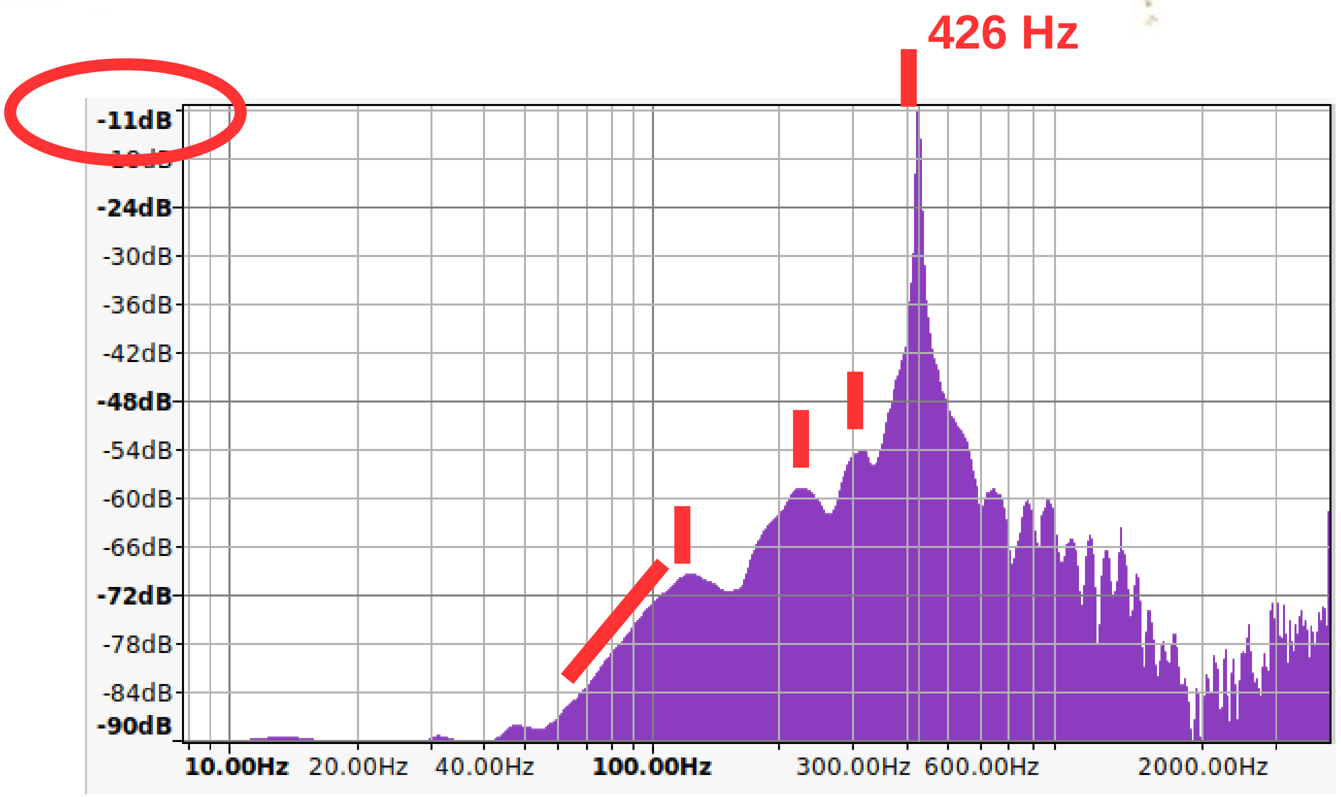
Ringbacktone Vodaphone RO



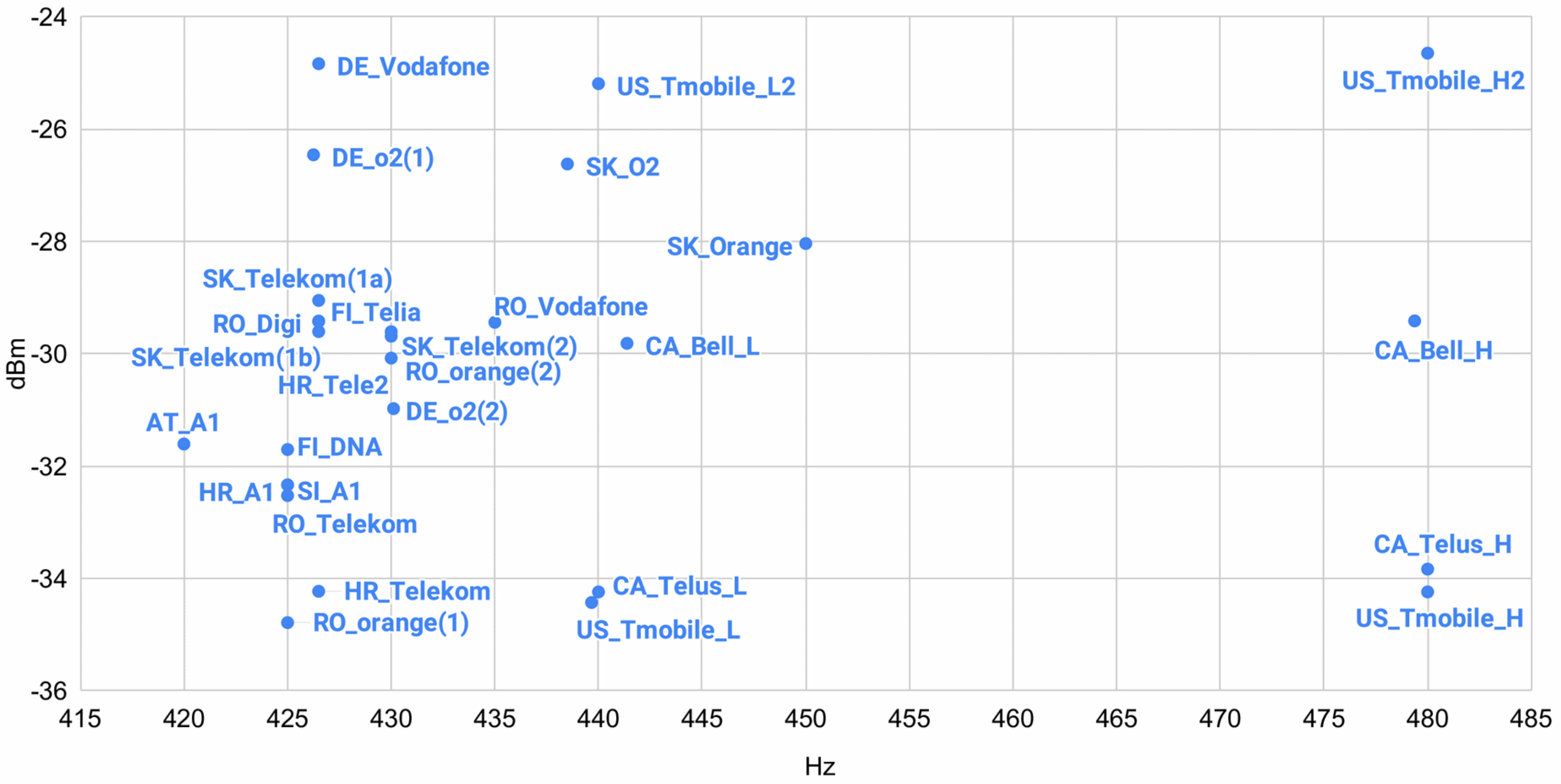
Ringbacktone Telekom DE



Ringbacktone O2 DE



Amplitude vs. Frequency



User Tracking w/ Call Progress Tones

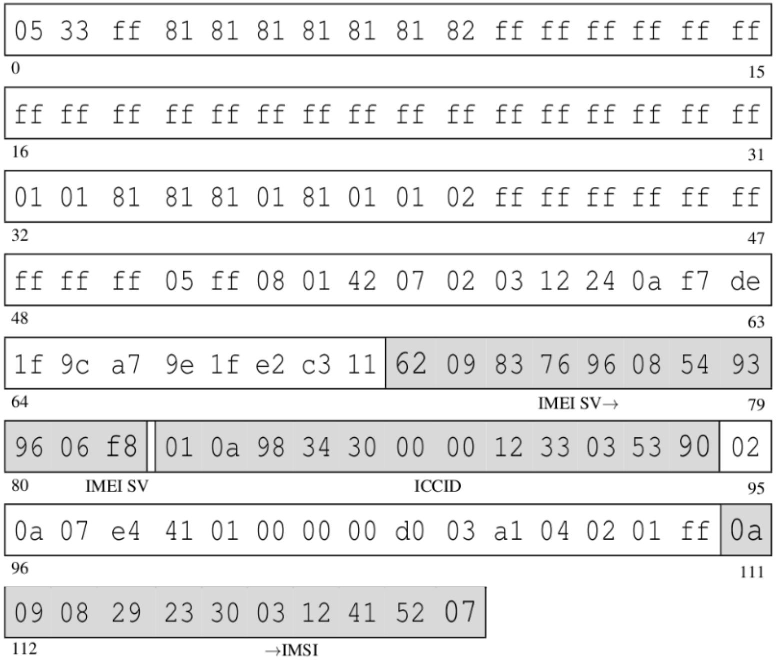
- Amplitude/Frequency(ies) already very distinctive
- One call, and you know the operator (and country) the called is in.
- Some corner cases exist
  - Sometimes more than one route/setting exist
  - Newer systems (e.g., VoLTE) show more conformity
  - Legacy voice (CSFB) works best

Measurement & Exploits (Selection)

Exhibit C: Proactive SIM Communication

Proactive SIM

- SIMs are microcontrollers
  - Many can run JAVA “cardlets”
- Can initiate ... on their own
  - SMS, TCP, UDP, Launch URLs
  - Request GPS, SSID, neighbor measurements, time, ...
- Some SIMs are known to “phone home” when switching to roaming mode.



See 3GPP 31.111

Measure & Exploit MNOs Globally

- Archibald can now measure, test, and develop exploits globally
- Roaming fuses MNOs to act as one
  - With interesting side effects
- We showed three use cases:
  - Free riding, locate clients, & proactive SIM

Don’t text and ride

https://mobileatlas.eu

@GGegenhuber
gabriel.gegenhuber -at- univie.ac.at

@atrox_at
adrian.dabrowski -at- cispa.de